

Marco integrativo GQM + PRAGMATIC para indicadores NIST CSF 2.0

1. Enfoque general

Este marco integra la metodología Goal-Question-Metric (GQM) con los criterios PRAGMATIC para diseñar y evaluar métricas de ciberseguridad alineadas con NIST CSF 2.0 y objetivos nacionales.[web:35][web:36][web:41][web:46][web:5][web:22]

1.1. GQM aplicado a NIST CSF 2.0

- **Goal (Objetivo):** declaración de propósito ligada a funciones CSF (GV, ID, PR, DE, RS, RC) y a metas nacionales (resiliencia, continuidad de servicios esenciales, etc.).[web:5][web:22]
- **Question (Pregunta):** cuestiones específicas que permiten saber si avanzamos hacia el objetivo.[web:35][web:39][web:41]
- **Metric (Métrica):** datos cuantitativos o cualitativos que responden a las preguntas con evidencia.[web:35][web:37][web:38][web:43][web:46]

1.2. Criterios PRAGMATIC

Cada métrica se puntúa de 1 (muy pobre) a 5 (muy buena) en los nueve criterios PRAGMATIC:[web:40][web:44][web:47]

- **P – Predictivo:** ¿ayuda a anticipar resultados futuros (incidentes, fallos, brechas)?
- **R – Relevante:** ¿está claramente alineada con objetivos de negocio y riesgo?
- **A – Accionable:** ¿lleva a decisiones o acciones concretas?
- **G – Genuino:** ¿refleja la realidad sin manipulaciones fáciles o incentivos perversos?
- **M – Significativo (Meaningful):** ¿es comprensible y valiosa para los stakeholders?
- **A – Preciso (Accurate):** ¿es fiable y suficientemente exacta para su uso?
- **T – Oportuno (Timely):** ¿se obtiene con la frecuencia adecuada para tomar decisiones?
- **I – Independiente:** ¿no depende en exceso de juicios subjetivos o de una sola fuente?
- **C – Rentable (Cost-effective):** ¿su coste de obtención/uso es razonable frente al beneficio?

2. Ejemplo estructurado por indicador

A continuación se ilustra, para un conjunto de indicadores clave derivados del informe, cómo se documenta GQM + PRAGMATIC de forma homogénea.

Indicador 1 – Cobertura de MFA en cuentas de alto riesgo (PR)

- Goal: Reducir la probabilidad de compromiso de cuentas críticas mediante autenticación reforzada, alineado con la función PROTECT (PR) de NIST CSF 2.0.[web:5]
- Questions:
- Q1. ¿Qué porcentaje de cuentas de alto riesgo está protegido por MFA según la política vigente?
- Q2. ¿Se está incrementando la cobertura de MFA con el tiempo?
- Metrics:
- M1. % de cuentas de alto riesgo con MFA activo frente al total de cuentas de alto riesgo.
- M2. Variación trimestral (%) de la cobertura de MFA.

Evaluación PRAGMATIC (escala 1-5)

- Predictivo: 4 – Una alta o creciente cobertura de MFA se correlaciona con menor probabilidad de compromisos por robo de credenciales.
- Relevante: 5 – Directamente alineado con objetivos de protección de accesos y requisitos normativos.
- Accionable: 5 – Valores bajos activan campañas de despliegue y refuerzo de políticas.
- Genuino: 4 – Difícil de “maquillar” si se audita contra directorios y sistemas de autenticación.
- Significativo: 5 – Fácil de entender por dirección y técnicos.
- Preciso: 4 – Depende de la calidad de los inventarios de cuentas y sistemas de IAM.
- Oportuno: 4 – Puede actualizarse mensualmente o trimestralmente con esfuerzo razonable.
- Independiente: 3 – Depende de sistemas internos, pero puede verificarse con auditorías.
- Rentable: 4 – Automatizable con conectores a IAM/IdP.

Indicador 2 – Tiempo medio de detección (MTTD) (DE)

- Goal: Reducir el tiempo necesario para detectar incidentes, mejorando la función DETECT (DE) y limitando el impacto potencial.[web:5][web:22]
- Questions:
- Q1. ¿Cuánto tiempo transcurre de media entre la ocurrencia de un incidente y su detección?
- Q2. ¿El MTTD disminuye tras inversiones en monitorización y análisis?
- Metrics:
- M1. MTTD en horas para incidentes clasificados como graves en el último año.
- M2. Tendencia trimestral del MTTD (en % de reducción/aumento).

Evaluación PRAGMATIC

- Predictivo: 4 – Un MTTD alto anticipa incidentes más dañinos; su reducción sugiere mejor contención futura.
- Relevante: 5 – Clave para resiliencia y cumplimiento de políticas de detección.
- Accionable: 5 – Valores altos justifican inversiones en SOC, SIEM, EDR, formación.
- Genuino: 3 – Puede verse afectado por criterios de clasificación y de “inicio del incidente”.
- Significativo: 4 – Muy comprensible para gestión, especialmente cuando se compara con benchmarks.
- Preciso: 3 – Depende de registros de tiempo coherentes y definición homogénea de incidente.
- Oportuno: 4 – Puede calcularse mensualmente, trimestralmente o tras cada incidente.
- Independiente: 3 – Se nutre de sistemas internos, pero puede validarse en auditorías.
- Rentable: 4 – Se puede automatizar a partir de sistemas de ticketing y SIEM.

Indicador 3 – Cumplimiento de RTO en ejercicios de recuperación (RC)

- Goal: Asegurar que los procesos críticos se recuperan dentro de los tiempos de RTO acordados, reforzando la función RECOVER (RC).[web:5]
- Questions:
 - Q1. ¿Qué porcentaje de servicios críticos alcanza su RTO durante ejercicios de recuperación?
 - Q2. ¿La tendencia mejora a lo largo de los últimos ejercicios?
- Metrics:
 - M1. % de servicios críticos que cumplen su RTO en el último ejercicio.
 - M2. Evolución de ese porcentaje en los últimos 3 ejercicios.

Evaluación PRAGMATIC

- Predictivo: 5 – Excelente indicador de la probabilidad de que, ante una crisis real, los tiempos se cumplan.
- Relevante: 5 – Directamente vinculado a continuidad de negocio y obligaciones regulatorias.
- Accionable: 5 – Resultados pobres activan planes de mejora, inversiones en DR y revisiones de diseños.
- Genuino: 4 – Difícil de manipular si los ejercicios son supervisados y documentados.
- Significativo: 5 – Fácil de entender por negocio y reguladores.
- Preciso: 4 – Depende de la calidad de los cronogramas y definición exacta de “servicio recuperado”.
- Oportuno: 3 – Se mide típicamente 1-2 veces al año; suficiente para planificación.
- Independiente: 4 – Puede ser verificado por terceros (auditoría, regulador).
- Rentable: 3 – Los ejercicios tienen coste, pero la métrica es un subproducto valioso.

Indicador 4 – Cobertura de inventario automatizado de activos (ID)

- Goal: Lograr visibilidad casi completa de los activos, requisito previo para gestionar riesgo, proteger y detectar, dentro de la función IDENTIFY (ID).[web:5]
- Questions:
- Q1. ¿Qué porcentaje de activos estimados está detectado y registrado automáticamente?
- Q2. ¿Se está reduciendo la brecha entre inventario estimado y real?
- Metrics:
- M1. % de activos descubiertos automáticamente frente a estimación total.
- M2. Número de activos “huérfanos” identificados por auditorías o escaneos ad hoc.

Evaluación PRAGMATIC

- Predictivo: 4 – Una mala visibilidad anticipa problemas en todas las demás funciones.
- Relevante: 5 – Base para cualquier programa serio de ciberseguridad.
- Accionable: 5 – Si la cobertura es baja, se invierte en herramientas y procesos de descubrimiento.
- Genuino: 4 – Contrastable con escaneos independientes.
- Significativo: 4 – Claro para los equipos técnicos y razonablemente entendible para dirección.
- Preciso: 3 – La “estimación total” de activos puede ser incierta.
- Oportuno: 4 – Se puede refrescar mensualmente o trimestralmente.
- Independiente: 3 – Depende de herramientas internas, pero se puede auditar.
- Rentable: 3 – Requiere invertir en soluciones de inventario/CMDB, con claro retorno.

Indicador 5 – Porcentaje de proveedores críticos con cláusulas de ciberseguridad (GV.SC)

- Goal: Reducir riesgos derivados de terceros mediante requisitos contractuales y de gestión, apoyando la subfunción de Supply Chain Risk Management (GV.SC).[web:5][web:45]
- Questions:
- Q1. ¿Qué porcentaje de proveedores clasificados como críticos tiene cláusulas contractuales específicas de ciberseguridad?
- Q2. ¿Se está ampliando esa cobertura con el tiempo?
- Metrics:
- M1. % de proveedores críticos con cláusulas de ciberseguridad definidas y firmadas.
- M2. Número de contratos críticos revisados/actualizados al año.

Evaluación PRAGMATIC

- Predictivo: 4 – Buena cobertura reduce probabilidad/impacto de incidentes vía terceros.
- Relevante: 5 – Muy alineado con requisitos regulatorios recientes (NIS2, DORA, etc.).
- Accionable: 5 – Si el porcentaje es bajo, se lanza un programa de revisión contractual.
- Genuino: 4 – Verificable mediante revisión documental.
- Significativo: 4 – Muy comprensible para gestores de compras y riesgo.
- Preciso: 4 – Requiere inventario claro de proveedores críticos.
- Oportuno: 3 – Se revisa anualmente o en ciclos de contratación.
- Independiente: 4 – Puede auditarse de forma externa.
- Rentable: 4 – El coste es el de revisar contratos, a menudo necesario por otras razones.

3. Uso del marco en práctica

1. Seleccionar los objetivos estratégicos de ciberseguridad (nacionales o corporativos).
2. Derivar para cada objetivo un conjunto de preguntas clave (GQM).
3. Asociar a cada pregunta una o varias métricas operativas específicas.
4. Evaluar cada métrica según PRAGMATIC para priorizar cuáles se mantienen, mejoran o sustituyen.
5. Construir un cuadro de mando donde solo sobrevivan las métricas que pasan el filtro PRAGMATIC con puntuaciones altas globales.

Este marco permite asegurar trazabilidad desde los objetivos de alto nivel hasta los datos técnicos de operación, y a la vez evitar la proliferación de métricas que “quedan bien” pero no predicen, no son accionables o cuestan más de lo que valen.